

Security & Incident Response Policy — AURIQ LTD

(Auriq Wealth)

Owner: Kevin Maingi, Founder / Information Security Manager **Applies to:** the Auriq Wealth product (web app, iOS/Android apps) and all supporting infrastructure operated by AURIQ LTD. **Status:** Version 1.1 — last reviewed 2026-08-09. Reviewed at least annually and after any material incident or architecture change.

This document is the company's primary security policy. It exists to satisfy our obligations as a registered agent of Finexer LTD for Account Information Services (AIS) and under UK GDPR / the Data Protection Act 2018. It covers our security controls, our incident-response process, and our data-breach procedures.

1. Scope & responsibilities

AURIQ LTD processes UK consumers' bank account and transaction data, obtained with the customer's explicit consent through Finexer's (and other providers') open-banking APIs, to deliver a personal financial-management dashboard (AIS only — we never initiate payments or move customer money).

- **Information Security Manager (ISM):** Kevin Maingi — accountable for security, incident response, and regulator/partner notification.
- All personnel (currently founder-operated; future staff and contractors) must follow this policy and report suspected incidents immediately to the ISM.

2. Security controls (summary)

Area	Control
Bank token storage	Access/refresh tokens encrypted at rest with Fernet (AES); encryption key held only in environment/secret files, never in source control.
Secrets	All secrets injected via environment or git-ignored key files. <code>.env</code> , session/token/webhook/VAPID/APNs keys are git-ignored and never committed.
Authentication	Signed, time-limited session tokens (7-day expiry) verified on every request; access restricted to an email allowlist.
Transport security	TLS in transit; HTTPS terminated by managed platforms (Vercel/Railway) and MongoDB Atlas.
Network	Managed-platform firewalls, application-level rate limiting on auth/webhook routes, restricted CORS, and IP allow-listing of production API keys where supported (incl. Finexer).
Data store	MongoDB Atlas, access-controlled, hosted in a UK/EU region.
Backups	Encrypted nightly database backups to Cloudflare R2 with 30-day retention.
Webhooks	Signature/secret verification on inbound provider webhooks.

Area	Control
Monitoring	Platform logs (Vercel/Railway/Atlas) and optional application error monitoring (Sentry).

Detailed operational security notes live in `CLAUDE.md` , `DEPLOY.md` , and `ADR.md` .

3. Incident classification

Severity	Definition	Examples
Critical (P1)	Confirmed or likely unauthorised access to customer bank/personal data, or loss of the token-encryption key.	Database exfiltration, leaked <code>TOKEN_ENCRYPTION_KEY</code> , account takeover.
High (P2)	Security control failure with potential for data exposure.	Auth bypass, exposed secret, exploited vulnerability without confirmed data loss.
Medium (P3)	Contained issue, no data exposure.	Blocked intrusion attempt, dependency vulnerability, misconfiguration caught before exploitation.
Low (P4)	Minor/no risk.	Isolated failed logins, spam.

4. Incident response process

Every incident follows this lifecycle. The ISM leads; timings below are targets.

1. **Detect & record** — Identify via monitoring, provider (Finexer) notification, user report, or internal discovery. Open an incident record with timestamp, reporter, and initial description.
2. **Contain** — Stop the bleeding. As applicable: revoke affected bank access tokens; revoke affected Finexer consents (`DELETE /consents/{id}`); disable affected accounts/allowlist access; rotate compromised secrets (`SESSION_SECRET` , `TOKEN_ENCRYPTION_KEY` , webhook secrets, provider API keys); block malicious IPs; take affected services offline if necessary.
3. **Assess scope** — Determine what data, which customers, and which systems are affected, and whether personal data was accessed, altered, or lost. Classify severity (§3).
4. **Notify** — - **Finexer**: report any breach of our systems, non-compliance, money-laundering attempt, or other incident **as soon as practicable and within 24 hours** of becoming aware, per our agency agreement. - **ICO**: report a personal-data breach **within 72 hours** of becoming aware where it poses a risk to individuals' rights and freedoms. - **Affected individuals**: notify without undue delay where the breach is likely to result in a **high risk** to their rights and freedoms. - Maintain an internal record of the incident regardless of whether external notification is required.
5. **Remediate** — Eradicate the root cause, restore from clean backups if needed, apply patches/config fixes, and verify the fix.
6. **Post-incident review** — Within 5 working days of closure, document root cause, timeline, impact, actions taken, and preventative measures. Feed lessons back into controls and this policy.

5. Data-breach procedures

A **personal data breach** is any breach of security leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to customer personal or financial data.

- Any suspected breach is treated as an incident (§4) and, if it involves personal data, triggers the ICO 72-hour assessment and the Finexer 24-hour notification.
- The ISM maintains a breach register recording: date/time of discovery, nature of the breach, categories and approximate number of individuals and records affected, likely consequences, and measures taken.
- Where notification thresholds are met, notifications include the nature of the breach, contact point, likely consequences, and mitigating measures.

6. Data retention

AURIQ LTD retains customer data only for as long as necessary to provide the service and to meet legal obligations, in line with the UK GDPR storage-limitation principle. This section defines our retention periods and deletion mechanisms.

Status: DRAFT — periods marked [CONFIRM] are provisional defaults pending founder sign-off. An automated purge job to enforce the account/transaction retention limits is still to be implemented; deletion is currently user-initiated (see mechanisms below).

Data category	Retention period	Mechanism
Bank account & transaction data	Retained while the customer's account is open and the open-banking consent is active. Deleted within [CONFIRM: 30] days of account closure, consent withdrawal or expiry, or after [CONFIRM: 12] months of account inactivity.	User-initiated now (account deletion / bank disconnect); scheduled auto-purge to be added.
Open-banking consent records (status, timestamps)	Life of the connection plus [CONFIRM: 12] months for audit, then deleted.	Consent records.
Encrypted bank access tokens	Deleted immediately on bank disconnect or account deletion; overwritten on consent renewal.	Cascade on disconnect + remote consent revoke.
AI chat sessions	7 days.	Automatic TTL.
Savings-insight caches	30 days.	Automatic TTL.
Webhook event logs	30 days.	Automatic TTL.
Database backups	30-day rolling window (nightly encrypted backups to Cloudflare R2).	Automatic prune.
Records required by law or regulator (if any)	Statutory minimum, then deleted.	Manual review.

Deletion mechanisms: - **Right to erasure:** a customer can delete their entire account, removing their records across all data stores; deletions cascade to their accounts and transactions. - **Bank disconnect:**

removes that connection's accounts and transactions and revokes the provider (e.g. Finexer) consent. - **Backups:** data belonging to deleted customers ages out of encrypted backups within the 30-day backup window.

Retention periods are reviewed at least annually.

7. Contacts

- **Internal (ISM):** Kevin Maingi — kevin.maingi@auriqltd.co.uk / 07398773162.
- **Finexer:** TBC.
- **ICO:** report at ico.org.uk or the ICO breach helpline within 72 hours.

8. Review

This policy is reviewed at least annually, and after any material incident, change of provider, or significant change to the system architecture. Version history is tracked below.

Version	Date	Change
1.0	2026-08-09	Initial policy.
1.1	2026-08-09	Added Data retention section (draft).